

INFORMATION SECURITY

Course Code: CACS459

Class Load: 6 Hrs. / Week
(Theory: 3 Hrs. Practical: 3 Hrs.)

Course Overview

1. Course Description:

- The course introduces theoretical and practical concepts of computer and information security.
- It covers cryptographic algorithms, authentication systems, access controls, malicious logics, network security, and security audits.

2. Course Objectives:

- To familiarize students with security concepts, policies, and mechanisms to enable them to design, implement, and manage secure computer systems.

UNIT I: OVERVIEW OF COMPUTER SECURITY (4 HRS.)

- Topics

- I.1. Computer Security Concepts
- I.2. Computer Security, Information Security, Network Security
- I.3. Threats, Attacks and Assets
- I.4. Security Requirements
- I.5. Security Design Principles
- I.6. Attack Surfaces and Attack Trees
- I.7. Computer Security Strategy

COMPUTER SECURITY

Core Definition of Computer Security:

- **Computer Security** (also called cybersecurity or information security) is the practice of **protecting computer systems, networks, programs, and data from unauthorized access, damage, theft, or disruption.**
- Computer security refers to the **measures and controls** used to protect information system assets such as: **Hardware, Software, Firmware, Data, Communication systems.**

Example

- Using passwords to prevent others from accessing your files.
- Installing antivirus software to protect against malware.
- Encrypting data so attackers cannot read it.

THE CIA TRIAD

- The goal of Computer security is to ensure:
 - **Confidentiality**
 - **Integrity**
 - **Availability**
- These three principles are called the **CIA Triad**.

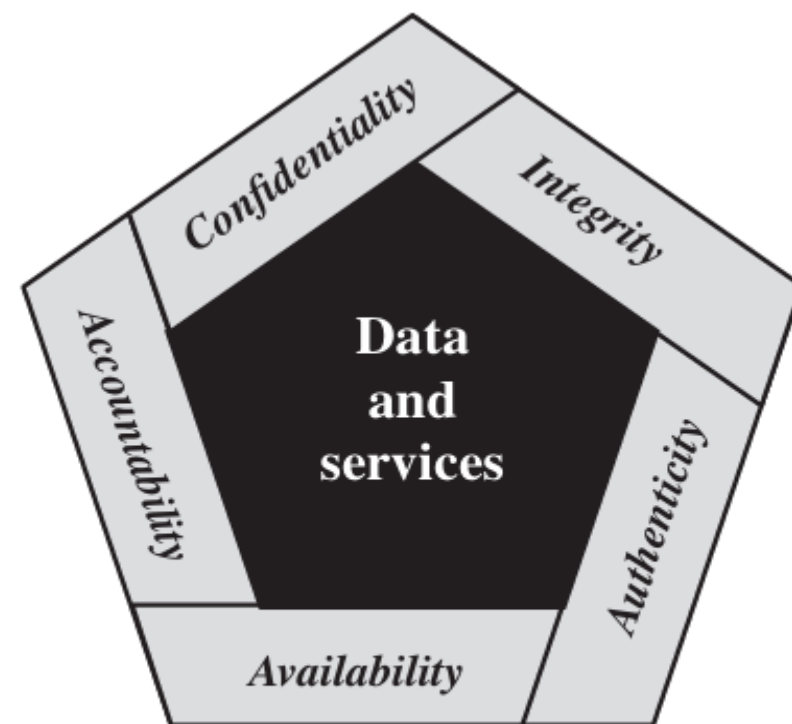


Figure 1.1 Essential Network and Computer Security Requirements

I. CONFIDENTIALITY

- Confidentiality refers to protecting information from unauthorized access or disclosure.
- It ensures that only authorized individuals or systems can access sensitive data.
- Data confidentiality refers to protecting sensitive data from unauthorized access.
- Privacy refers to allowing individuals to control how their personal information is collected, stored, and shared.
- A loss of confidentiality occurs when information is disclosed to unauthorized users.

2. INTEGRITY

- Integrity refers to maintaining the accuracy, consistency, and trustworthiness of data and systems.
- It ensures that information is modified only in authorized ways.
- Data integrity refers to ensuring that information is changed only by authorized users and processes.
- System integrity refers to ensuring that a system performs its intended function without unauthorized manipulation.
- A loss of integrity occurs when data is modified or destroyed without authorization.

3. AVAILABILITY

- Availability refers to ensuring that systems, applications, and data are accessible to authorized users whenever they are needed.
- It ensures timely and reliable access to information services.
- A loss of availability occurs when systems or services become unavailable due to failures or attacks.

There are some additional Important Concepts which are often considered extensions of the CIA triad.

4. Authenticity

- Authenticity refers to the property of being genuine and verifiable.
- It ensures that users are who they claim to be and that the source of information can be trusted.
- Authenticity helps establish confidence in the validity of messages and communications.

5. Accountability

- Accountability refers to the ability to trace system actions to a specific individual or entity.
- It ensures that users can be held responsible for their activities.
- Accountability supports auditing, intrusion detection, forensic investigation, and legal actions after incidents.

CHALLENGES OF ACHIEVING COMPUTER SECURITY

- Computer security is challenging because security mechanisms are often complex and require careful design.
- Attackers continuously try to discover weaknesses, and even a small vulnerability can be exploited.
- Security mechanisms require proper placement and management of secret information such as encryption keys.
- Security also requires continuous monitoring, which can be difficult in practice.
- Strong security sometimes reduces user convenience, which creates resistance from users.
- Organizations often invest in security only after experiencing a security incident.

COMPUTER SECURITY MODEL

- Computer security involves protecting valuable assets from threats by using countermeasures.
- The security model includes assets, vulnerabilities, threats, attacks, countermeasures, and risk.
- Organizations aim to reduce risk by implementing appropriate security controls.

COMPUTER SECURITY

- **Computer Security** (also called Cybersecurity) means protecting computer systems and their resources from unauthorized access, damage, or misuse.
- It focuses mainly on **individual computers or devices**.

Main Goals

- To Protect hardware (computers, storage devices)
- To Protect software (operating systems, applications)
- To Protect data stored in the system

Examples of Computer Security:

- Using antivirus software
- Setting passwords on a laptop
- Preventing malware attacks

INFORMATION SECURITY

- This is the **broadest** of the three. It focuses on protecting **information** in **any form** such as digital, physical (e.g., paper documents), or even spoken from unauthorized access, use, disclosure, disruption, modification, or destruction.
- Core goal of Information Security is to protect the **CIA triad**:
 - a) **Confidentiality** — Only authorized people can access the information.
 - b) **Integrity** — Information remains accurate and unaltered by unauthorized parties.
 - c) **Availability** — Authorized users can access the information when needed.
- It covers **all data**, including non-digital forms (locked filing cabinets, verbal NDAs, etc.).
- Examples of concerns → Data breaches, insider threats, physical theft of documents, social engineering, poor disposal of sensitive papers.
- Information Security is the **umbrella term** that includes digital aspects but extends beyond computers and networks.

NETWORK SECURITY

- **Network Security** means protecting computer networks and the data transmitted through them from unauthorized access, attacks, or misuse. It focuses on **communication between computers**.
- Network security covers devices like routers, switches, firewalls, virtual private networks (VPNs), wireless access points, and the network boundary (also called the perimeter). It also protects data while it is moving from one place to another.

Here are some common problems (threats) that network security deals with:

- **DDoS attacks** — These attacks flood the network with too much traffic so that normal users cannot use it.
- **Packet sniffing** — Someone secretly listens to or captures data packets as they travel across the network.
- **Man-in-the-middle attacks** — An attacker secretly stands between two communicating parties and reads or changes the messages.
- **Unauthorized Wi-Fi access** — People connect to a wireless network without permission.
- **Firewall misconfigurations** — Wrong settings in the firewall allow bad traffic to pass through.
- Intrusion into different parts of the network — Attackers break into one section and move to other sections.
- Network security uses tools and technologies such as: **Firewalls, Intrusion Detection Systems (IDS), VPN (Virtual Private Network), Secure communication protocols**

THREATS, ATTACKS, AND RELATED CONCEPTS

- **Threat:** Any circumstance/event with potential to adversely impact operations, assets, individuals, organizations, or nation via unauthorized access, destruction, disclosure, modification, or denial of service.
- **Threat Agent / Adversary:** Individual, group, organization, or government conducting attack related activities.

COMPUTER THREATS

- Computer threats are potential dangers that can harm computer systems, networks, or data by stealing, damaging, or disrupting them.
- Threats exploit system vulnerabilities to cause damage or gain unauthorized access.

Major Types of Computer Threats:

- **Malware** — Virus, Worm, Trojan, Ransomware, Spyware
- **Phishing** — Fake messages to steal sensitive information
- **Password Attacks** — Unauthorized access by guessing or stealing passwords
- **Denial of Service (DoS)** — Overloading systems to make them unavailable
- **Insider Threats** — Misuse by authorized users
- **Man-in-the-Middle Attacks** — Intercepting communication
- **Social Engineering** — Manipulating people for information
- **Physical Threats** — Theft, fire, hardware damage

COMPUTER THREATS...

Effects of Threats:

- Data loss or theft
- Financial damage
- Privacy violation
- System failure

Prevention Methods for Threats:

- Strong passwords & authentication
- Antivirus and firewalls
- Software updates
- Regular data backup
- User awareness

ATTACK

- A computer attack is an **actual attempt to harm or break into a system**, while a threat is only a possible danger.
- A **computer attack** is any deliberate action performed by an attacker to exploit vulnerabilities in a computer system, network, or application in order to gain unauthorized access, steal data, disrupt services, or cause damage.

TYPES OF ATTACKS

1. **Active attack:** Alters system resources or affects operation.
2. **Passive attack:** Learns/uses information without affecting resources.
3. **Insider attack:** From authorized entity inside security perimeter (insider misuses access).
4. **Outside attack:** From unauthorized outsider (e.g., pranksters to terrorists/governments on the Internet).

ACTIVE ATTACK

- An active attack is a type of attack in which the attacker alters system resources or affects the normal operation of a system. In an active attack, the attacker may modify, delete, or insert data into the system.
- An active attack can cause damage to the system, disrupt services, or create unauthorized changes.
- Active attacks are usually easier to detect than passive attacks because the system behavior changes.
- An example of an active attack is when a hacker changes the content of a website or performs a denial-of-service attack to stop a server from working.
- The main types of active attacks include :
 - a) masquerade attacks
 - b) replay attacks
 - c) message modification attacks
 - d) denial-of-service attacks.

TYPES OF ACTIVE ATTACKS

- **Masquerade Attack**

In a masquerade attack, the attacker pretends to be an authorized user in order to gain access to the system or perform actions that are normally restricted.

- **Replay Attack**

In a replay attack, the attacker captures valid data transmissions and retransmits them later to trick the system into performing unauthorized actions.

- **Modification of Messages**

In a modification of messages attack, the attacker changes the content of data while it is being transmitted over the network, causing the receiver to receive altered information.

- **Denial of Service (DoS) Attack**

In a denial-of-service attack, the attacker overloads system resources such as network bandwidth or server capacity, making the system unavailable to legitimate users.

PASSIVE ATTACK

- A **passive attack** is a type of attack where the attacker **only observes, monitors, or collects information** without changing the system or data.
- The system continues to operate normally, so these attacks are **hard to detect**.

Examples: Intercepting emails, Monitoring network traffic, Listening to confidential conversations

Characteristics

- No modification of data.
- No system disruption.
- Mainly used for information gathering.
- Very difficult to detect.

Types of Passive Attacks

- a) **Eavesdropping (Sniffing)**
Listening to private communication.
- b) **Traffic Analysis**
Studying communication patterns to gain information.

INSIDER ATTACK

- An **insider attack** occurs when a person **inside the organization** (authorized user) misuses their access to harm the system or steal information.
- The attacker already has permission, which makes this attack **very dangerous**.

Characteristics

- Performed by employees, staff, or trusted users.
- Uses legitimate access privileges.
- Hard to detect because activities look normal.

Examples

- Employee stealing company data
- Administrator abusing privileges
- Staff leaking confidential information

OUTSIDE ATTACK

- An **outside attack** is performed by someone **outside the organization** who does not have authorized access to the system.
- These attackers try to break security protections to gain entry.

Attackers May Include

- Hackers, Cyber criminals, Terrorist groups, Pranksters
- Government agencies

Characteristics

- Unauthorized access attempt.
- Often uses malware, phishing, or hacking tools.
- Usually detected by firewalls or security systems.

Examples: Internet hacking attempts, Phishing emails, Malware attacks from unknown sources

Table 1.2 Threat Consequences, and the Types of Threat Actions that Cause Each Consequence

Threat Consequence	Threat Action (Attack)
Unauthorized Disclosure A circumstance or event whereby an entity gains access to data for which the entity is not authorized.	Exposure: Sensitive data are directly released to an unauthorized entity. Interception: An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. Inference: A threat action whereby an unauthorized entity indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from characteristics or by-products of communications. Intrusion: An unauthorized entity gains access to sensitive data by circumventing a system’s security protections.
Deception A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.	Masquerade: An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity. Falsification: False data deceive an authorized entity. Repudiation: An entity deceives another by falsely denying responsibility for an act.
Disruption A circumstance or event that interrupts or prevents the correct operation of system services and functions.	Incapacitation: Prevents or interrupts system operation by disabling a system component. Corruption: Undesirably alters system operation by adversely modifying system functions or data. Obstruction: A threat action that interrupts delivery of system services by hindering system operation.
Usurpation A circumstance or event that results in control of system services or functions by an unauthorized entity.	Misappropriation: An entity assumes unauthorized logical or physical control of a system resource. Misuse: Causes a system component to perform a function or service that is detrimental to system security.

Source: Based on RFC 4949

ASSETS IN A COMPUTER SECURITY MODEL

- In computer security, an **asset** refers to any valuable resource that needs to be protected from threats.
- Assets are important because attackers may attempt to damage, steal, or misuse them.
- The main categories of computer system assets include:
 - a) Hardware
 - b) Software
 - c) Data
 - d) Communication networks.

SYSTEM RESOURCES (ASSETS)

a) **Hardware Assets**

- Hardware assets include computer systems and other data processing devices.
- Hardware also includes storage devices and communication equipment used for transmitting data.
- Protecting hardware is important to ensure system functionality and availability.

b) **Software Assets**

- Software assets include operating systems, system utilities, and application programs.
- Software protection is necessary because attackers may modify or destroy programs to disrupt operations.
- Unauthorized changes to software can lead to incorrect system behavior.

SYSTEM RESOURCES (ASSETS)

c) Data Assets

- Data assets include files, databases, and security-related information such as password files.
- Data is often the most valuable asset because it may contain sensitive or confidential information.
- Protecting data ensures confidentiality, integrity, and availability.

d) Communication and Network Assets

- Communication assets include local and wide area network links used to transmit data.
- Network devices such as routers, switches, and bridges are also considered assets.
- Securing communication networks prevents unauthorized access and data interception.

SECURITY REQUIREMENTS

- **Security requirements** are basically the rules, controls, and measures that an organization puts in place to protect its computer systems, data, and users.
- They answer the question: “*What do we need to do to keep information safe, accurate, and available?*”
- Security requirements can be categorized into two main types: **Technical Controls** and **Management Controls**.
 - a) **Technical Controls (Technology-Based)**
 - b) **Management Controls (Human and Policy-Based)**
 - c) **Combination of Both Technical and Management Controls**

TECHNOLOGY-BASED SECURITY REQUIREMENTS

- Technical controls are protections that rely on software, hardware, or other technical tools to secure systems.
- **Access control** ensures that only authorized users are allowed to log in or perform specific actions within a system.
- **Authentication** verifies the identity of users, devices, or processes before granting access to resources.
- **System protection** involves measures such as encrypting data or blocking malicious traffic to prevent unauthorized access or attacks.
- **Data integrity** ensures that information is accurate and complete by detecting and preventing unauthorized modifications.

MANAGEMENT CONTROLS (HUMAN AND POLICY-BASED) SECURITY REQUIREMENTS

- Management controls are protections that rely on people, processes, and organizational policies rather than just technology.
- **Training and awareness programs** educate staff about security risks and teach them how to handle sensitive information safely.
- **Auditing** involves maintaining logs of user actions and system events so that misuse or security incidents can be investigated.
- **Risk assessment and planning** require regularly reviewing threats, preparing for emergencies, and ensuring proper data backups.
- **Physical security** protects hardware, facilities, and other resources from unauthorized access, theft, or environmental hazards.

COMBINATION OF BOTH TECHNICAL AND MANAGEMENT CONTROLS

- Some security areas require both technical measures and management practices to function effectively.
- **Configuration management** ensures that systems are set up securely and that all changes are properly tracked and documented.
- **Incident response** prepares organizations for security breaches by detecting incidents and responding promptly to minimize damage.
- **Media protection** involves securing storage devices and safely destroying or wiping data when it is no longer needed to prevent unauthorized access.

SECURITY DESIGN PRINCIPLES

Introduction

- Despite years of research, no security design can completely prevent all unauthorized actions or eliminate all security flaws.
- To guide the development of protection mechanisms, experts have agreed upon a set of fundamental security design principles.
- These principles help in creating more secure systems by reducing vulnerabilities and mitigating potential risks.

KEY SECURITY DESIGN PRINCIPLES

- **Economy of mechanism:** Security measures should be simple and small in design, making them easier to test, maintain, and less likely to contain exploitable flaws.
- **Fail-safe defaults:** Systems should deny access by default and grant permission only when explicitly allowed, ensuring safer failure modes.
- **Complete mediation:** Every access to a resource must be checked for authorization, rather than relying on cached or previous access decisions.
- **Open design:** Security mechanisms should be open to public scrutiny, so users and experts can verify their correctness and reliability.
- **Separation of privilege:** Access to sensitive resources should require multiple independent privileges, such as multi-factor authentication or separate processes for high-privilege tasks.

KEY SECURITY DESIGN PRINCIPLES...

- **Least privilege:** Users and processes should operate with only the minimum privileges necessary to perform their tasks.
- **Least common mechanism:** Shared mechanisms should be minimized to reduce unintended communication paths and potential security vulnerabilities.
- **Psychological acceptability:** Security mechanisms should be user-friendly and minimally obstructive, aligning with users' mental models of protection.
- **Isolation:** Critical resources, processes, and security mechanisms should be isolated from public access and from each other to prevent tampering or unauthorized use.
- **Encapsulation:** Data and procedures should be grouped into protected modules so that internal structures are accessed only through controlled entry points.

KEY SECURITY DESIGN PRINCIPLES

- **Modularity:** Security functions should be developed as separate, reusable modules to simplify maintenance, upgrades, and secure implementation.
- **Layering (Defense in Depth):** Multiple overlapping security measures should be used so that the failure of one layer does not leave the system unprotected.
- **Least astonishment:** Programs and interfaces should behave in a way that is predictable to the user, minimizing confusion and mistakes.

ORGANIZATIONAL SECURITY MEASURES

- **Personnel security:** Organizations must ensure employees and third-party service providers are trustworthy and follow security policies.
- **Risk assessment:** Organizations should periodically evaluate risks to operations, assets, and individuals to identify vulnerabilities.
- **Systems and services acquisition:** Security must be considered when acquiring or developing systems, including third-party services and software restrictions.
- **System and communications protection:** Systems should monitor and control information at external and internal boundaries, using secure designs and engineering practices.
- **System and information integrity:** Flaws should be identified and corrected promptly, malicious code should be blocked, and security alerts should be monitored and addressed.

ATTACK SURFACES

- An **attack surface** refers to the total set of points in a system where an attacker can attempt to enter, extract data, or cause damage.
- In simple terms, it includes all possible vulnerabilities that can be reached and exploited by a malicious user.
- Attack surfaces are generally divided into three main categories:
 1. Network Attack Surface
 2. Software Attack Surface
 3. Human Attack Surface

ATTACK SURFACES

I. Network Attack Surface

- This includes vulnerabilities related to network connections and communication systems.
- Attackers may exploit weaknesses in network protocols, open ports, or internet-connected services to gain unauthorized access or disrupt operations.

Examples:

- Open ports on servers
- Weak firewall configurations
- Unsecured Wi-Fi networks
- Communication protocol flaws

ATTACK SURFACES

2. Software Attack Surface

- This consists of vulnerabilities present in software applications, operating systems, and services that process external input. Programs that interact with users or other systems are especially at risk.

Examples:

- Web applications and web forms
- Email processing programs
- Operating system services
- Bugs in application code

ATTACK SURFACES

3. Human Attack Surface

- This involves vulnerabilities caused by people rather than technology.
- Attackers often exploit human behavior through manipulation or mistakes.

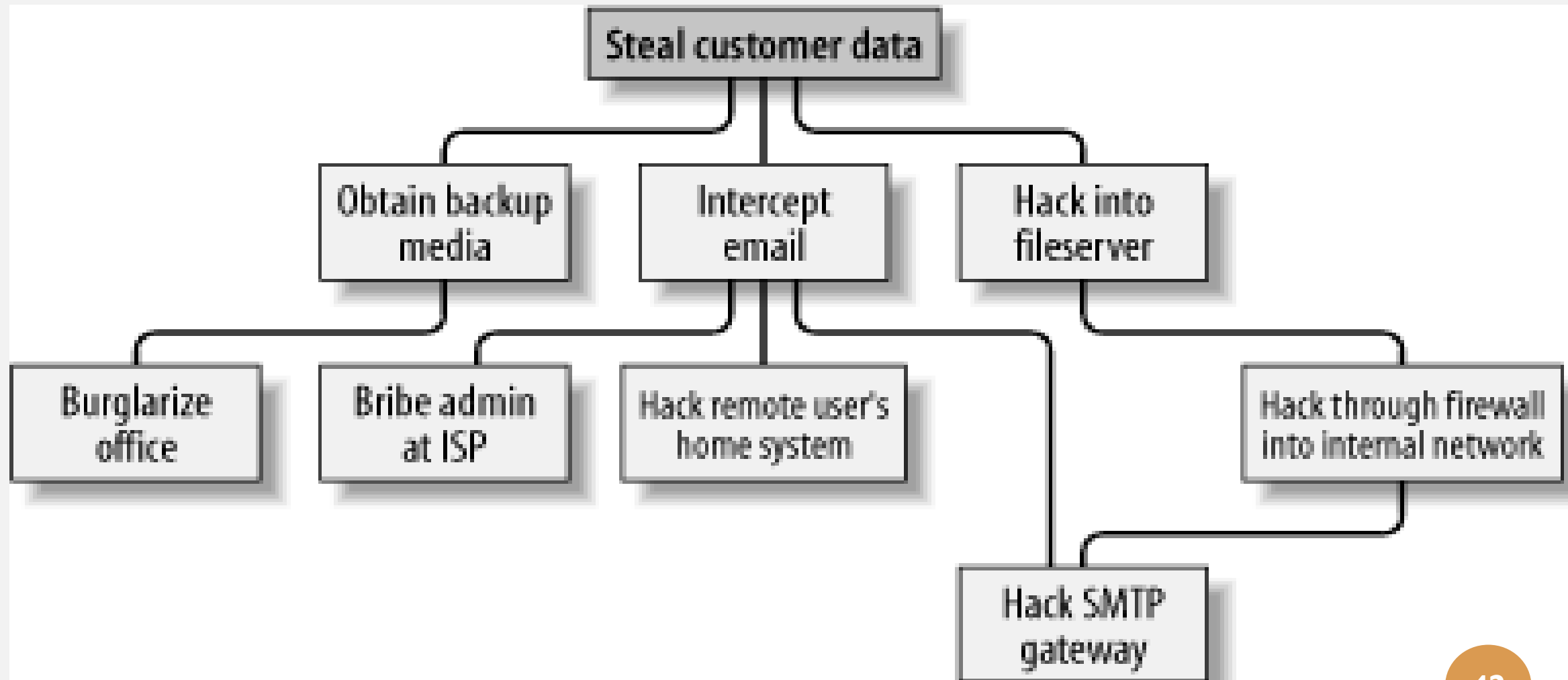
Examples:

- Social engineering attacks (phishing, impersonation)
- Weak passwords
- Insider threats
- Employees with access to sensitive information

ATTACK TREES

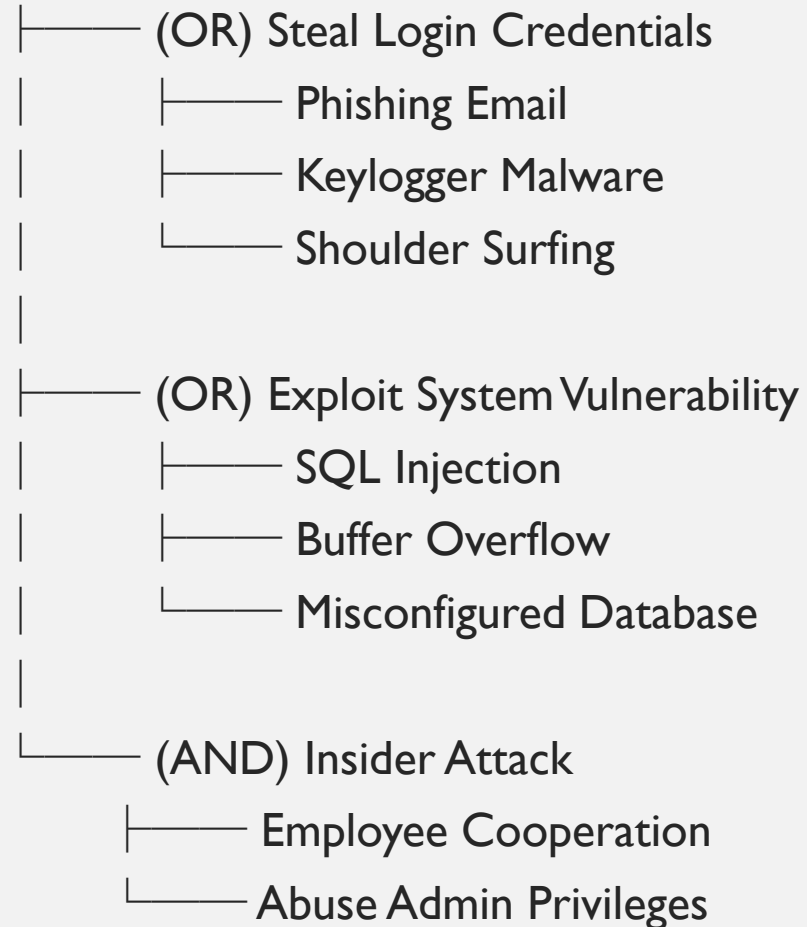
- An **attack tree** is a hierarchical diagram that maps all possible ways an attacker can reach a goal.
- The **root node** represents the attack objective, while branches and sub nodes represent steps or subgoals.
- **Leaf nodes** are the specific actions an attacker can take, and nodes are classified as **AND-nodes** (all subgoals must succeed) or **OR-nodes** (any one subgoal is sufficient).
- Attack trees help security analysts document attacks, identify vulnerabilities, and plan effective countermeasures.

ATTACK TREES...



ATTACK TREES...

Access Restricted Library Records



WHY ATTACK TREES ARE IMPORTANT

Attack trees help in:

1. Risk Analysis

- Identify the most likely attack paths.
- Estimate cost, time, and skill required.

2. Vulnerability Identification

- Reveal system weaknesses.
- Highlight missing security controls.

3. Security Planning

- Design countermeasures.
- Prioritize defenses.

4. Threat Modeling

- Useful in software engineering security phase.
- Can be included during **requirements analysis** (which is useful for your software engineering presentations).

COMPUTER SECURITY STRATEGY

- Computer security strategy refers to the overall approach used to protect computer systems, networks, and data from unauthorized access, misuse, damage, or disruption.
- A comprehensive security strategy ensures that security requirements are clearly defined, properly implemented, and verified to work correctly.
- According to security experts, a complete computer security strategy consists of three major aspects:
 - A. Specification / Policy** – What the security system is supposed to achieve
 - B. Implementation / Mechanisms** – How the security requirements are enforced
 - C. Correctness / Assurance** – Whether the implemented security actually works as intended
- These three components together provide a structured and reliable approach to designing and managing computer security.

A. SECURITY POLICY

- The first step in developing security services and mechanisms is to establish a **security policy**.
- A security policy is a **formal statement of rules and practices** that regulate how an organization **manages, protects, and distributes** sensitive information and resources.
- A formal policy can be enforced using technical controls (such as software and hardware mechanisms) as well as administrative and operational procedures.

A. SECURITY POLICY...

A security manager must consider several important factors while designing a policy:

1. Value of Assets Being Protected

- Organizations must determine the importance and value of their resources, such as: Financial data, Customer information, Intellectual property, Operational systems
- Higher-value assets require stronger protection.

2. Vulnerabilities of the System

- Vulnerabilities are weaknesses that attackers can exploit. These may include: Software bugs, Weak passwords, Misconfigured systems, Outdated security patches
- Understanding vulnerabilities helps determine necessary protections.

3. Potential Threats and Likelihood of Attacks

- Threat analysis includes identifying: Possible attackers, Types of attacks, Probability of occurrence
- Risk assessment combines vulnerability and threat likelihood.

A. SECURITY POLICY...

Security decisions always involve trade-offs between competing factors.

1. Ease of Use versus Security

- Security mechanisms often reduce convenience.
- Examples: Strong authentication requires users to remember complex passwords. Or , Firewalls may slow network performance.

2. Cost of Security versus Cost of Failure and Recovery

- Implementing security involves direct and indirect costs, including: Purchasing hardware and software, Maintenance and administration , Training employees
- These costs must be compared with potential losses from security failures, such as: Financial damage, Legal penalties, Reputation loss, Recovery expenses
- Thus, security policy is not purely technical; it is also a **business decision**, often influenced by legal and regulatory requirements.

B. SECURITY IMPLEMENTATION

- Once a policy is established, it must be implemented using appropriate mechanisms. Security implementation involves four complementary approaches:

1. Prevention: Prevention aims to stop attacks before they occur. Although perfect prevention is rarely possible, many threats can be minimized through preventive controls.

If strong encryption and proper key protection are used, unauthorized access to transmitted data can be effectively prevented.

2. Detection: In some cases, complete prevention is not feasible. Therefore, systems must be able to detect attacks when they occur.

Detection mechanisms include: Intrusion detection systems (IDS), Security monitoring tools, Log analysis, Detection of denial-of-service attacks

Early detection helps reduce damage and enables faster response.

B. SECURITY IMPLEMENTATION

3. Response: Response mechanisms take action when an attack is detected to minimize damage and stop further harm.

Examples include: Blocking malicious IP addresses, Terminating compromised user sessions, Isolating infected systems from the network, Activating incident response procedures, Effective response reduces the impact of ongoing attacks.

4. Recovery: Recovery focuses on restoring systems and data after an attack or failure. Examples include: Data backups and restoration, Disaster recovery planning, System repair and reconfiguration, Business continuity planning.

Recovery ensures that operations can resume quickly after a security incident.

C. ASSURANCE AND EVALUATION

- Users and organizations that rely on computer systems require confidence that security mechanisms function correctly. This leads to the concepts of **assurance** and **evaluation**.

Assurance

- Assurance is the degree of confidence that a system correctly enforces its security policy. It addresses two important questions:
 - i. Does the security design meet its requirements?
 - ii. Does the implementation correctly follow the design?
- Assurance covers both: System design, System implementation

C. ASSURANCE AND EVALUATION

- **Evaluation:** Evaluation is the process of examining and testing a computer system or product against specific security criteria.
- Evaluation may include:
 - Functional testing
 - Security audits
 - Penetration testing
 - Formal analysis
 - Certification against standards
- The primary goal of evaluation is to create standardized criteria that allow organizations to compare different security products and determine their effectiveness.